

Projet fil rouge — Audit d'infrastructure & de sécurité d'un SaaS de production

Architecture IA · Année 5 NoCode / LowCode & IA · Épreuve finale

1. La mission

Vous êtes une **société de conseil** — seul ou avec un associé (donnez-lui un nom, c'est votre équipe). Un **client** vous confie une mission.

Votre client : KodeSaaS (Maxime Nicole), propriétaire d'eRezo — un SaaS de gestion de contacts et d'événements professionnels, construit vite, en vibecoding (développement piloté par IA).

Le client vous mandate pour un **audit d'infrastructure et de sécurité** de son application. Sa demande est simple :

« Mon SaaS tourne, mais je ne sais pas s'il est **sûr** ni s'il est **bien hébergé**. Faites-moi un audit, dites-moi ce qui ne va pas, et dites-moi comment il faudrait construire une **V2** propre et sécurisée. »

Votre livrable : un **rapport d'audit d'infrastructure et de sécurité**, avec des recommandations priorisées pour la V2. Vous **ne codez rien** et vous **n'analysez pas le code** de l'application. Un audit d'infra et de sécurité se fait **de l'extérieur** : c'est exactement votre périmètre.

Votre matière première :

- ce que vous découvrez pendant le **pentest** (les vraies failles d'eRezo) ;
- ce que vous **observez** de l'application et de son infrastructure en production (<https://erezo.fr>) : hébergement, HTTPS, en-têtes, configuration exposée... ;
- **le guide du module**, qui rassemble les bonnes pratiques — c'est là que vous piochez pour vos recommandations.

Pas besoin d'être expert en développement. On note votre **posture de conseil** : diagnostiquer ce qui ne va pas côté infra et sécurité, et proposer une manière propre de reconstruire.

2. Ce qu'on attend de vous

Votre rapport tient en **deux temps**.

Partie 1 — L'audit de l'existant : qu'est-ce qui ne va pas sur eRezo aujourd'hui ?

Sans entrer dans le code. À partir du pentest et de ce que vous observez de l'extérieur.

a) Infrastructure

- Où et comment l'application est-elle **hébergée** ? (ce que vous arrivez à identifier : serveur, hébergeur, CDN...)
- Le site est-il en **HTTPS** ? Le certificat est-il correct ?
- Que révèlent les **en-têtes HTTP** et la **configuration** ? (en-têtes de sécurité présents ou absents, messages d'erreur qui en disent trop, fichiers ou pages qui ne devraient pas être exposés...)
- Voit-on des **traces de « fait vite »** : environnement de dev visible en prod, informations techniques qui fuient, etc. ?

b) Sécurité

- Les **failles** trouvées pendant le pentest, **priorisées** : **P0** (à corriger tout de suite) · **P1** (important) · **P2** (amélioration).
- Pour chaque faille : où elle se trouve, ce qu'elle permet, comment la corriger.

Partie 2 — Les recommandations pour la V2

Comment construire une V2 **bien hébergée** et **sécurisée**. Pour chaque thème, expliquez **la bonne pratique** et **ce que vous recommandez concrètement** au client.

1. **Une infrastructure propre et fiable** — bon hébergement, HTTPS partout, séparation des environnements (dev / production), sauvegardes.
2. **Une application sécurisée** — les grandes règles pour éviter précisément les failles que vous avez trouvées (contrôle des accès, en-têtes de sécurité, configuration, données exposées).
3. **Une mise en ligne maîtrisée** — un déploiement propre, ce qui se passe entre « ça marche sur mon poste » et « c'est en production ».
4. **Le respect des données des utilisateurs** — les règles de base sur les données personnelles.
5. **Un socle fait pour durer** (*pour aller plus loin*) — ce qui rend un projet solide et reprenable dans le temps (organisation, tests, documentation). Le guide couvre ces points.

On ne vous impose aucun vocabulaire technique. Ce qu'on note, c'est que vous ayez **compris la bonne pratique** et que vous sachiez **la conseiller clairement** à un client. Si vous employez en plus les bons termes du métier, c'est un bonus.

3. Livrables & jalons

Quand	Livrable
En séance	Pentest réalisé en classe — vous collectez les failles réelles d'eRezo (voir le protocole de pentest, obligatoire et à signer).
En séance	Soutenance orale : vous présentez votre audit et vos grandes recommandations à votre client.
Vendredi 17 juillet 2026	Rapport d'audit d'infra & de sécurité (PDF) rendu — l'audit de l'existant + les recommandations V2, au propre.

⚠ **Le pentest se fait uniquement en séance, en classe.** Aucun test sur eRezo hors du temps de classe. Le rapport rendu le 17 juillet met au propre le travail réalisé en cours. **Anonymisez** toute donnée personnelle réelle croisée pendant les tests.

Format du rendu : un rapport clair de **5 à 8 pages**, adressé à votre client. Concis et concret vaut mieux que long et flou.

4. Comment vous êtes évalués (/20)

Volet	Points	Ce qu'on regarde
Audit sécurité (findings)	6	Vos failles sont réelles, bien décrites et priorisées P0/P1/P2. Vous savez reproduire une faille en direct.
Audit infrastructure	4	Votre lecture de l'hébergement, du HTTPS, des en-têtes et de la configuration est juste et bien expliquée.
Recommandations V2	6	Vos recommandations sont justes, concrètes et actionnables . On sent que vous avez compris ce qui fait un SaaS bien hébergé et sûr.
Restitution & posture conseil	4	Vous présentez clairement, vous vous adressez au client, vous défendez vos choix face aux questions.
Bonus vocabulaire pro	+2	Vous employez juste le vocabulaire du métier (celui du guide) sans que ça ait été exigé.

Un audit **simple mais juste et bien conseillé** vaut mieux qu'un audit exhaustif et confus. On évalue votre **raisonnement de conseil**, pas votre niveau technique.

5. Méthode : l'IA comme copilote

- Utilisez vos assistants IA pour **accélérer** votre travail — comprendre les failles, lire une configuration, structurer vos recommandations, formuler clairement — mais **vérifiez toujours**. Une IA qui « invente » une faille inexistante, c'est un finding faux qui vous coûte des points.
- **Étudiez le guide** du module : il couvre les bonnes pratiques de la Partie 2. C'est votre référence.

- Pour la sécurité : **jamais de test sans cadre**. Vous ne lancez le pentest qu'après avoir lu et signé le protocole.

Bon audit. 🔍